CHAPTER 5
INTRUSION DETECTION AND PREVENTION

ROLISHA STHAPIT

LH-5

CONTENTS

- Intruders, Intrusion Detection, Intrusion Detection Analysis Approaches, Host-Based Intrusion Detection, Network-Based Intrusion Detection, Hybrid Intrusion Detection, Intrusion Detection Exchange Format, Honeypots, Intrusion Prevention System

INTRUDERS

- Intruders are attackers or hackers who tries to get information from target system or damage the system.
- Intrusion is the action performed by the intruders.
- One of the two most publicized threats to security is the intruder (the other is viruses), generally referred to as a hacker or cracker. There are three classes of intruders found:
- **Masquerader:** An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account. The masquerader is likely to be an outsider.
- **Misfeasor:** A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges. The misfeasor generally is an insider.
- **Clandestine user:** An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection. The clandestine user can be either an outsider or an insider.

- Intruder attacks range from the benign to the serious. At the benign end of the scale, there are many people who simply wish to explore internets and see what is out there. At the serious end are individuals who are attempting to read privileged data, perform unauthorized modifications to data, or disrupt the system.
- One of the key threats to security is the use of some form of hacking by an intruder, often referred to as a hacker or cracker. Verizon indicate that 92% of the breaches (violation) they investigated were by outsiders, with 14% by insiders, and with some breaches involving both outsiders and insiders. They also noted that insiders were responsible for a small number of very large dataset compromises.
- This trend emphasizes the need to use defense-in-depth strategies, since such targeted attacks may be designed to bypass perimeter defenses such as firewalls and network-based Intrusion detection systems (IDSs). As with any defense strategy, an understanding of possible motivations of the attackers can assist in designing a suitable defensive strategy.

- **Types of Intruders:**
- There are following broad classes of intruders: cyber criminals, activists, state sponsored organizations and others.
- **Cyber criminals:** Are either individuals or members of an organized crime group with a goal of financial reward, to achieve this, their activities may include identity theft, theft of financial credentials, corporate espionage, data theft, or data ransoming. Typically, they are young, often Eastern European, Russian, or southeast Asian hackers, who do business on the Web. They meet in underground forums with names like DarkMarket.org and theftservices.com to trade tips and data and coordinate attacks.

- **Activists:** They are either individuals, usually working as insiders, or members of a larger group of outsider attackers, who are motivated by social or political causes. They are also known as **hacktivists**, and their skill level is often quite low. The aim of their attacks is often to promote and publicize their cause, typically through website defacement, denial of service attacks, or the theft and distribution of data that results in negative publicity or compromise of their targets. Well-known recent examples include the activities of the groups Anonymous and LulzSec, and the actions of Chelsea (formerly Bradley) Manning and Edward Snowden.
- **State-sponsored organizations:** They are groups of hackers sponsored by governments to conduct espionage or sabotage activities. They are also known as Advanced Persistent Threats (APTs), due to the covert nature and persistence over extended periods involved with many attacks in this class.

Sabotage is the deliberate act of destroying, damaging, or disrupting something, especially for political or military advantage.

- **Others:** They are hackers with motivations other than those listed above, including classic hackers or crackers who are motivated by technical challenge or by peer-group esteem and reputation. Many of those responsible for discovering new categories of buffer overflow vulnerabilities could be regarded as members of this class. Also, given the wide availability of attack toolkits, there is a pool of “hobby hackers” using them to explore system and network security, who could potentially become recruits for the above classes.

Skill Levels of Intruders:

Across these classes of intruders, there is also a range of skill levels seen. These can be broadly classified as:

- **Apprentice:** Hackers with minimal technical skill who primarily use existing attack toolkits. They likely comprise the largest number of attackers, including many criminal and activist attackers. Given their use of existing known tools, these attackers are the easiest to defend against. They are also known as “script-kiddies” due to their use of existing scripts (tools).

- **Journeyman:** They are hackers with sufficient technical skills to modify and extend attack toolkits to use newly discovered, or purchased, vulnerabilities or to focus on different target groups. They may also be able to locate new vulnerabilities to exploit that are similar to some already known. A number of hackers with such skills are likely found in all intruder classes listed above, adapting tools for use by others. The changes in attack tools make identifying and defending against such attacks harder.
- **Master:** They are hackers with high-level technical skills capable of discovering brand new categories of vulnerabilities, or writing new powerful attack toolkits. Some of the better-known classical hackers are of this level, as clearly are some of those employed by some state-sponsored organizations. This makes defending against these attacks of the highest difficulty.

- **Examples of Intrusion:**

Intrusion is the action performed by the intruders. Following are the examples of intrusion:

- Performing a remote root compromise of an e-mail server
- Defacing (Spoil) a Web server
- Guessing and cracking passwords
- Copying a database containing credit card numbers
- Viewing sensitive data, including payroll records and medical information, without authorization
- Running a packet sniffer on a workstation to capture usernames and passwords
- Using a permission error on an anonymous FTP server to distribute pirated software and music files
- Dialing into an unsecured modem and gaining internal network access
- Posing as an executive, calling the help desk, resetting the executive's e-mail password, and learning the new password
- Using an unattended, logged-in workstation without permission

- **Intruder Behavior:** The techniques and behavior patterns of intruders are constantly shifting, to exploit newly discovered weaknesses and to evade detection and countermeasures. However, intruders typically use steps from a common attack methodology. Intruders can show the following activities or behaviors:
- **Target Acquisition and Information Gathering**: Where the attacker identifies and characterizes the target systems using publicly available information, both technical and non-technical, and the use network exploration tools to map target resources.
- **Initial Access:** The initial access to a target system, typically by exploiting the remote network vulnerability by guessing weak authentication credentials by brute force method used in a remote service or via the installation of malware on the system using some form of social engineering or drive-by-download attack.
- **Privilege Escalation**: Actions taken on the system, typically via the local access vulnerability to increase the privileges available to the attacker to enable their desired goals on the target system.

- **Information Gathering or System Exploit:** Actions by the attacker to access or modify information or resources on the system, or to navigate to another target system.
- **Maintaining Access:** Actions such as the installation of backdoors or other malicious software or through the addition of covert (secret) authentication credentials or other configuration changes to the system, to enable continued access by the attacker after the initial attack.
- **Covering Tracks:** Where the attacker disables or edits audit logs to remove evidence of attack activity, and uses rootkits and other measures to hide covertly (Secretly) installed files or code.

INTRUSION DETECTION SYSTEM (IDS)

- **Security Intrusion:** A security event, or a combination of multiple security events, that constitutes a security incident in which an intruder gains, or attempts to gain, access to a system (or system resource) without having authorization to do so.
- **Intrusion Detection:** A security service that monitors and analyzes system events for the purpose of finding, and providing real-time or near real-time warning of, attempts to access system resources in an unauthorized manner.
- **Responses of IDS:**
- The following table shows all the possible response statuses of the IDS when it faces an incident. If the system detects an incident when it has actually occurred, it is working correctly: a True Positive (TP) has taken place. However, the system is malfunctioning if the incident has occurred, but the system does not warn about it: it results in a False Negative (FN). Similarly, if there is no incident and the system identifies it inaccurately, we will be facing a False Positive (FP), while we will be dealing with a True Negative (TN) if the system does not warn in such case.

	An incident occurs	No incident occurs
An alert is generated	True Positive (TP)	False Positive (FP)
No alert is generated	False Negative (FN)	True Negative (TN)

- **Components of IDS**: The IDS comprises three logical components:

Sensors:

Sensors are responsible for collecting data. The input for a sensor may be any part of a system that could contain evidence of an intrusion. Types of inputs to a sensor include network packets, log files, and system call traces. Sensors collect and forward this information to the analyzer.

Analyzers:

Analyzers receive input from one or more sensors or from other analyzers. The analyzer is responsible for determining if an intrusion has occurred. The output of this component is an indication that an intrusion has occurred. The output may include evidence supporting the conclusion that an intrusion occurred. The analyzer may provide guidance about what actions to take as a result of the intrusion. The sensor inputs may also be stored for future analysis and review in a storage or database component.

User interface:

The user interface to the IDS enables a user to view output from the system or control the behavior of the system. In some systems, the user interface may equate to a manager, director, or console component.

Comprises three logical components:

- Sensors - collect data
- Analyzers - determine if intrusion has occurred
- User interface - view output or control system behavior

- **Types of IDS:**
- An IDS may use a single sensor and analyzer, such as a classic (Host-based IDS) HIDS on a host or (Network-based IDS) NIDS in a firewall device. More sophisticated IDSs can use multiple sensors, across a range of host and network devices, sending information to a centralized analyzer and user interface in a distributed architecture.
- IDSs are often classified based on the source and type of data analyzed, as:
- **Host-based IDS (HIDS):** Monitors the characteristics of a single host and the events occurring within that host, such as process identifiers and the system calls they make, for evidence of suspicious activity.
- **Network-based IDS (NIDS):** Monitors network traffic for particular network segments or devices and analyzes network, transport, and application protocols to identify suspicious activity.
- **Distributed or hybrid IDS:** Combines information from a number of sensors, often both host and network-based, in a central analyzer that is able to better identify and respond to intrusion activity.

- **Basic Principles of IDS:** Authentication facilities, access control facilities, and firewalls all play a role in countering intrusions. Another line of defense is intrusion detection, and this has been the focus of much research in recent years. This interest is motivated by a number of considerations, including the following:

1. If an intrusion is detected quickly enough, the intruder can be identified and ejected from the system before any damage is done or any data are compromised. Even if the detection is not sufficiently timely to preempt the intruder, the sooner that the intrusion is detected, the less the amount of damage and the more quickly that recovery can be achieved.
2. An effective IDS can serve as a deterrent (blocker/prevent), thus acting to prevent intrusions.
3. Intrusion detection enables the collection of information about intrusion techniques that can be used to strengthen intrusion prevention measures.

- Intrusion detection is based on the assumption that the behavior of the intruder differs from that of a legitimate user in ways that can be quantified.
- Figure suggests, in abstract terms, the nature of the task confronting the designer of the IDS. Although the typical behavior of an intruder differs from the typical behavior of an authorized user, there is an overlap in these behaviors.

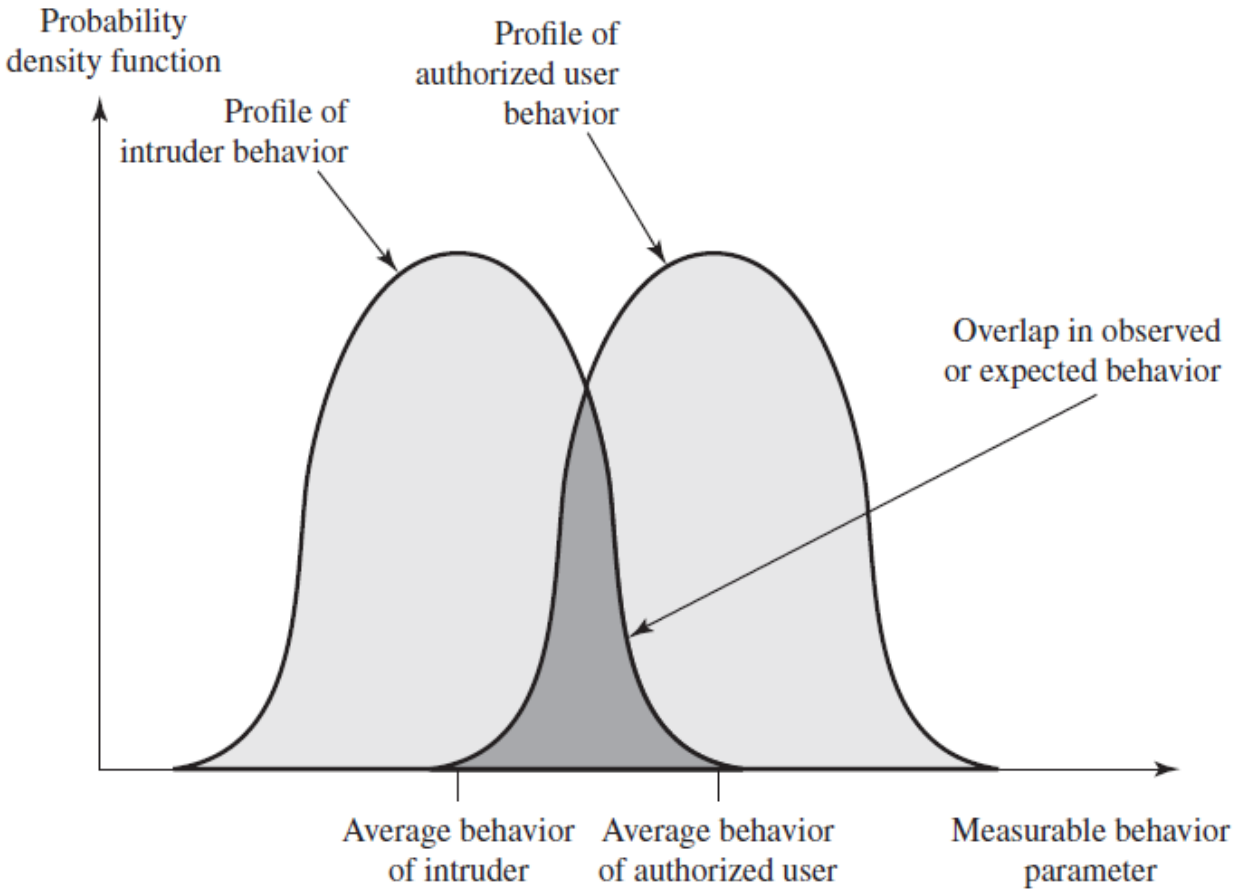


Fig: Profiles of Behavior of Intruders and Authorized Users

- Thus, a loose interpretation of intruder behavior, which will catch more intruders, will also lead to a number of **false positives**, or false alarms, where authorized users are identified as intruders.
- On the other hand, an attempt to limit false positives by a tight interpretation of intruder behavior will lead to an increase in **false negatives** or intruders not identified as intruders.
- Thus, there is an element of compromise and art in the practice of intrusion detection. Ideally you want an IDS to have a high detection rate, that is, the ratio of detected to total attacks, while minimizing the false alarm rate, the ratio of incorrectly classified to total normal usage.

— false positives: authorized users identified as intruders.
— false negatives: Intruders is not identified as intruders.

- ***Case Study:***
- In an important early study of intrusion, Anderson postulated that one could, with reasonable confidence, distinguish between an outside attacker and a legitimate user.
- Patterns of legitimate user behavior can be established by observing past history, and significant deviation from such patterns can be detected. Anderson suggests that the task of detecting an inside attacker (a legitimate user acting in an unauthorized fashion) is more difficult, in that the distinction between abnormal and normal behavior may be small. Anderson concluded that such violations would be undetectable solely through the search for anomalous (*abnormal*) behavior.
- However, insider behavior might nevertheless (*still*) be detectable by intelligent definition of the class of conditions that suggest unauthorized use. These observations, which were made in 1980, remain true today.

- ***<u>The Base-Rate Fallacy:</u>***
- *It is a misconception of intrusion detection rate.*

- To be of practical use, The IDS should detect a substantial (*real*) percentage of intrusions while keeping the false alarm rate at an acceptable level. If only a modest (*satisfactory*) percentage of actual intrusions are detected, the system provides a false sense of security.

- On the other hand, if the system frequently triggers an alert when there is no intrusion (*a false alarm*), then either system managers will begin to ignore the alarms, or much time will be wasted analyzing the false alarms.

- Unfortunately, because of the nature of the probabilities involved, it is very difficult to meet the standard of high rate of detections with a low rate of false alarms. In general, if the actual numbers of intrusions is low compared to the number of legitimate uses of a system, then the false alarm rate will be high unless the test is extremely discriminating.

- This is an example of a phenomenon known as the *base-rate fallacy*. A study of existing IDSs, indicated that current systems have not overcome the problem of the base-rate fallacy.

- ***Requirements***
- Following are the desirable consideration for the IDS. It must

- Run continually with minimal human supervision.
- Be fault tolerant in the sense that it must be able to recover from system crashes and re-initializations.
- Resist subversion. The IDS must be able to monitor itself and detect if it has been modified by an attacker.
- Impose a minimal overhead on the system where it is running.
- Be able to be configured according to the security policies of the system that is being monitored.
- Be able to adapt to changes in system and user behavior over time.
- Be able to scale to monitor a large number of hosts.
- Provide graceful degradation of service in the sense that if some components of the IDS stop working for any reason, the rest of them should be affected as little as possible.
- Allow dynamic reconfiguration; that is, the ability to reconfigure the IDS without having to restart it.

ANALYSIS APPROACHES

- IDSs typically use one of the following alternative approaches to analyze sensor data to detect intrusions:

  - Anomaly Detection
  - Signature or Heuristic Detection

Example:

•**Anomaly Detection**: A user typically accesses the system from one location during business hours but suddenly logs in from a foreign IP at midnight. Anomaly detection would flag this as suspicious.

•**Signature Detection**: The IDS identifies a known malware file signature in an email attachment, matching it to a database of known threats and flagging it as malicious.

Anomaly detection	Signature/Heuristic detection
• Involves the collection of data relating to the behavior of legitimate users over a period of time • Current observed behavior is analyzed to determine whether this behavior is that of a legitimate user or that of an intruder	• Uses a set of known malicious data patterns or attack rules that are compared with current behavior • Also known as misuse detection • Can only identify known attacks for which it has patterns or rules

- ***Anomaly detection:***
- The anomaly detection approach involves first developing a model of legitimate user behavior by collecting and processing sensor data from the normal operation of the monitored system in a training phase. This may occur at distinct times, or there may be a continuous process of monitoring and evolving the model over time. Once this model exists, current observed behavior is compared with the model in order to classify it as either legitimate or anomalous activity in a detection phase this action is done at high level of confidence. This comparison decides whether current behavior is that of a legitimate user or alternatively that of an intruder.

- A variety of classification approaches are used, which broadly categorized as:

- **Statistical:** Analysis of the observed behavior using univariate (single attribute), multivariate (multiple attribute), or time-series models of observed metrics.
- **Knowledge based:** Approaches use an expert system that classifies observed behavior according to a set of rules that model legitimate behavior.
- **Machine-learning:** Approaches automatically determine a suitable classification model from the training data using data mining techniques.

- A variety of machine-learning approaches have been tried, with varying success. These include:

- **Bayesian networks:** Encode probabilistic relationships among observed metrics.
- **Markov models:** Develop a model with sets of states, some possibly hidden, interconnected by transition probabilities.
- **Neural networks:** Simulate human brain operation with neurons and synapse between them, that classify observed data.
- **Fuzzy logic:** Uses fuzzy set theory where reasoning is approximate, and can accommodate uncertainty.
- **Genetic algorithms:** Uses techniques inspired by evolutionary biology, including inheritance, mutation, selection and recombination, to develop classification rules.
- **Clustering and outlier detection:** Group the observed data into clusters based on some similarity or distance measure, and then identify subsequent data as either belonging to a cluster or as an outlier.

A key limitation of anomaly detection approaches used by IDSs, particularly the machine-learning approaches, is that they are generally only trained with legitimate data, unlike many of the other applications where both legitimate and anomalous training data is used. The lack of anomalous training data, which occurs given the desire to detect currently unknown future attacks, limits the effectiveness of some of the techniques listed above.

- ***<u>Signature or Heuristic detection:</u>***
- It uses a set of known malicious data patterns (signatures) or attack rules (heuristics) that are compared with current behavior to decide if is that of an intruder. It is also known as misuse detection. This approach can only identify known attacks for which it has patterns or rules.
- **Signature approaches** match a large collection of known patterns of malicious data against data stored on a system or in transit over a network. The signatures need to be large enough to minimize the false alarm rate, while still detecting a sufficiently large fraction of malicious data. This approach is widely used in antivirus products, in network traffic scanning proxies, and in NIDS.
- The advantages of this approach include the relatively low cost in time and resource use, and its wide acceptance.
- Disadvantages include the significant effort required to constantly identify and review new malware to create signatures able to identify it, and the inability to detect zero-day attacks for which no signatures exist.

- **Rule-based heuristic identification** involves the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses. Rule scan also be defined that identify suspicious behavior, even when the behavior is within the bounds of established patterns of usage. Typically, the rules used in these systems are specific to the machine and operating system.
- The most fruitful approach to developing such rules is to analyze attack tools and scripts collected on the Internet. These rules can be supplemented with rules generated by knowledgeable security personnel. In this latter case, the normal procedure is to interview system administrators and security analysts to collect a suite of known penetration scenarios and key events that threaten the security of the target system.
- In essence**, anomaly approaches** aim to define normal, or expected, behavior, in order to identify malicious or unauthorized behavior.
- **Signature or heuristic-based approaches** directly define malicious or unauthorized behavior. They can quickly and efficiently identify known attacks.
- However, only anomaly detection is able to detect unknown, zero-day attacks, as it starts with known good behavior and identifies anomalies to it. Given this advantage, clearly anomaly detection would be the preferred approach, were it not for the difficulty in collecting and analyzing the data required, and the high level of false alarms.

Signature approaches

- Match a large collection of known patterns of malicious data against data stored on a system or in transit over a network
- The signatures need to be large enough to minimize the false alarm rate, while still detecting a sufficiently large fraction of malicious data
- Widely used in anti-virus products, network traffic scanning proxies, and in NIDS

Rule-based heuristic identification

- Involves the use of rules for identifying known penetrations or penetrations that would exploit known weaknesses
- Rules can also be defined that identify suspicious behavior, even when the behavior is within the bounds of established patterns of usage
- Typically rules used are specific
- SNORT is an example of a rule-based NIDS

· **Anomaly-Based IDS**: Monitors normal behavior and flags deviations as potential threats. Good for detecting unknown attacks but may have higher false positives.

· **Signature-Based IDS**: Looks for known attack patterns and raises alerts for matches. Effective for known threats but cannot detect new, unknown threats.

- **Anomaly-Based IDS**
- **Anomaly IDS** detects unusual activities by learning what "normal" behavior looks like on a system or network and then flagging deviations from this norm as potential threats.
- **How it Works:**
- **Learns Normal Behavior:** Anomaly IDS monitors regular activity patterns such as typical user behavior, network traffic, or system performance.
- **Flags Deviations:** Once it understands what normal looks like, it watches for activities that deviate from this baseline. For instance, if a user who typically accesses certain files suddenly tries to access many sensitive files at once, the system might consider this suspicious.
- **Adaptability:** It can identify new or unknown threats that don't have a predefined signature.

- **Examples:**
- An IDS noticing a spike in network traffic at an unusual time.
- Detecting a user logging in from an unusual geographic location.
- **Signature-Based IDS**
- **Signature IDS** detects threats by looking for known patterns or signatures of malicious activities, similar to how antivirus software looks for known virus patterns.
- **How it Works:**
- **Known Patterns:** Signature IDS maintains a database of known attack patterns or signatures, such as specific data sequences or behavior patterns known to be used by attackers.
- **Matches Patterns:** It scans system activity or network traffic for these signatures and raises alerts when a match is found. For example, if a known malware signature is detected in network traffic, the IDS will flag it.
- **Examples:**
- Detecting a known malware signature in a downloaded file.
- Identifying a network scan pattern used by a known hacking tool.

INTRUSION DETECTION SYSTEM (IDS) ARCHITECTURE:

- An intrusion detection system is also an automated auditing mechanism.
- It consists of three main components agent, director and notifier.
- The agent acquires information from a target (such as a computer system).
- The director analyzes the data from the agents as required (usually to determine if an attack is in progress or has occurred).
- The director then passes this information to the notifier, which determines whether, and how, to notify the requisite entity.
- The notifier may communicate with the agents to adjust the logging if appropriate.

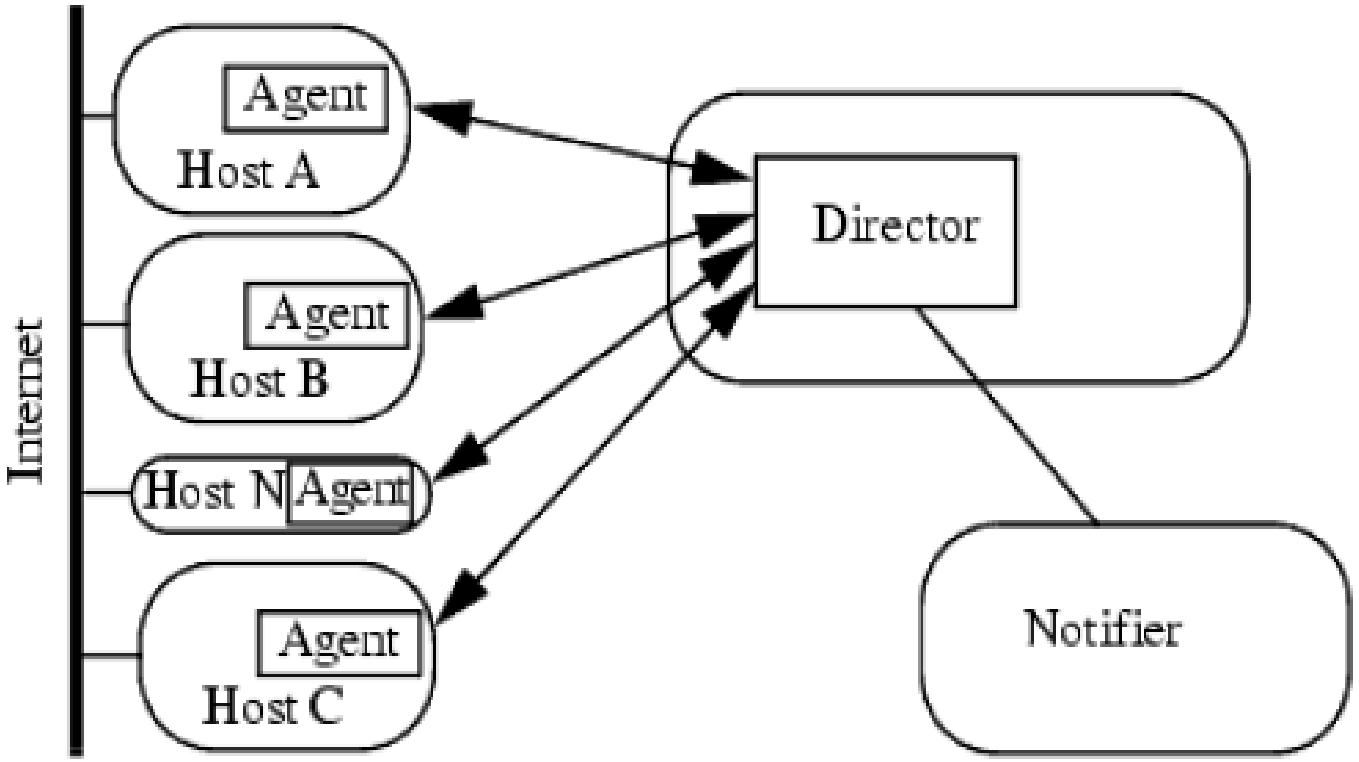


Figure: Architecture of an intrusion detection system. Hosts A, B, and C are general-purpose computers, and the agents monitor activity on them. Host N is designed for network monitoring, and its agent reports data gleaned from the Net to the director.

a. **Agent:**

- An agent obtains information from a data source (or set of data sources).
- The source may be a log file, another process, or a network.
- The information, once acquired, may be sent directly to the director.
- Usually, however, it is preprocessed into a specific format to save the director from having to do this.
- An agent can obtain information from a single host, from a set of hosts or from a network. Some information gathering techniques followed by agent are given below:

1. Host-Based Information Gathering

- Host-based agents usually use system and application logs to obtain records of events, and analyze them to determine what to pass to the director.
- The events to look for, and to analyze, are determined by the goals of the intrusion detection mechanism.
- The logs may be security-related logs called "Auditing Logs" or other logs such as accounting logs.
- A variant of host-based information gathering occurs when the agent generates its own information.
- Policy checkers do this. They analyze the state of the system, or of some objects in the system, and treat the results as a log.

2. Network-Based Information Gathering

- Network-based agents use a variety of devices and software to monitor network traffic.
- This technique provides information of a different flavor than host-based monitoring provides.
- It can detect network-oriented attacks, such as a denial of service attack introduced by flooding a network.
- It can monitor traffic for a large number of hosts.
- It can also examine the contents of the traffic itself (called content monitoring).

3. Combining Sources

- The goal of an agent is to provide the director with information so that the director can report possible violations of the security policy (intrusions). An aggregate of information is needed. However, the information can be viewed at several levels.

b. Director:

- The director itself reduces the incoming log entries to eliminate unnecessary and redundant records.
- It then uses an analysis engine to determine if an attack (or the precursor to an attack) is underway.
- The analysis engine may use any of, or a mixture of, several techniques to perform its analysis.
- Because the functioning of the director is critical to the effectiveness of the intrusion detection system, it is usually run on a separate system.
- This allows the system to be dedicated to the director's activity. It has the side effect of keeping the specific rules and profiles unavailable to ordinary users.
- Then attackers lack the knowledge needed to evade the intrusion detection system by conforming to known profiles or using only techniques that the rules do not include. The director must correlate information from multiple logs.

c. Notifier:

- The notifier accepts information from the director and takes the appropriate action.
- In some cases, this is simply a notification to the system security officer that an attack is believed to be underway.
- In other cases, the notifier may take some action to respond to the attack. Many intrusion detection systems use graphical interfaces.

HOST BASED INTRUSION DETECTION

- Host-based IDSs (HIDSs) add a specialized layer of security software to vulnerable sensitive systems; such as database servers and administrative systems.
- The HIDS monitors activity on the system in a variety of ways to detect suspicious behavior.
- The primary benefit of a HIDS is that it can detect both external and internal intrusions, something that is not possible either with network-based IDSs or firewalls.
- Host-based IDSs can use either anomaly or signature and heuristic approaches to detect unauthorized behavior on the monitored host.
- Some common data sources and sensors used in HIDS are:

- **Data Sources and Sensors:**

1. System call traces:

- A record of the sequence of systems calls by processes on a system, is widely acknowledged as the preferred data source for HIDS.
- While these work well on Unix and Linux systems, they are problematic on Windows systems due to the extensive use of DLLs that obscure which processes use specific system calls.
- Dynamic Link Library (DLL) s a collection of small programs, which can be called upon when needed by a larger program that is running in the computer.

2. Audit (log file) records:

- Most modern operating systems include accounting software that collects information on user activity.
- The advantage of using this information is that no additional collection software is needed.
- The disadvantages are that the audit records may not contain the needed information or may not contain it in a convenient form, and that intruders may attempt to manipulate these records to hide their actions.

3**. File integrity checksums:**

- A common approach to detecting intruder activity on a system is to periodically scan critical files for changes from the desired baseline, by comparing a current cryptographic checksums for these files, with a record of known good values.
- Disadvantages include the need to generate and protect the checksums using known good files, and the difficulty monitoring changing files. Tripwire is a well-known system using this approach.

4. Registry access:

- An approach used on Windows systems is to monitor access to the registry, given the amount of information and access to it used by programs on these systems.
- However this source is very Windows specific, and has recorded limited success.

The sensor gathers data from the chosen source, filters the gathered data to remove any unwanted information and to standardize the information format, and forwards the result to the IDS analyzer, which may be local or remote

- **Anomaly HIDS:**
- The majority of work on anomaly-based HIDS has been done on UNIX and Linux systems, given the ease of gathering suitable data for this work.
- While some earlier work used audit or accounting records, the majority is based on system call traces. System calls are the means by which programs access core kernel functions, providing a wide range of interactions with the low-level operating system functions.
- Hence they provide detailed information on process activity that can be used to classify it as normal or anomalous.
- Most modern operating systems have highly reliable options for collecting this type of information.
- The system call traces are then analyzed by a suitable decision engine. **Sequence Time-Delay Embedding (STIDE):** Introduced by Forrest et al., this algorithm compares observed sequences of system calls with training phase sequences to determine whether a sequence is normal or not.
- **Hidden Markov Models (HMM), Artificial Neural Networks (ANN), Support Vector Machines (SVM), and Extreme Learning Machines (ELM)** are alternative techniques used for classification.

- These approaches achieve intruder detection rates of 95-99% with low false positive rates (typically less than 5%), although these results are based on older test datasets.
- Recent advancements, including feature extraction from system call traces and ELM decision engines, promise even more effective HIDS products.
- Windows systems traditionally haven't used anomaly-based HIDS due to challenges posed by Dynamic Link Libraries (DLLs). DLLs act as intermediaries between process requests and the actual system call interface, hindering effective use of system call traces.
- However, a new approach leverages traces of key DLL function calls as an alternative data source, achieving comparable results to Linux system call trace HIDS. Monitoring thousands of distinct functions within DLLs can lead to more effective Windows HIDS capable of detecting zero-day attacks.

- While system call traces provide rich information, they impose a moderate load on monitored systems during data collection and classification. Training decision engines requires significant computational resources. Some HIDS approaches rely on audit log records, but they have a lower detection rate (around 80%) and are more susceptible to intruder manipulation.
- A further alternative to examining current process behavior, is to look for changes to important files on the monitored host. This uses a cryptographic check sum to check for any changes from the known good baseline for the monitored files.
- Typically all program binaries, scripts, and configuration files are monitored, either on each access, or on a periodic scan of the file system. The tripwire system is a widely used implementation of this approach, and is available for all major operating systems including Linux, Mac OSX and Windows. This approach is very sensitive to changes in the monitored files, as a result of intruder activity or for any other reason.
- However it cannot detect changes made to processes once they are running on the system. Other difficulties include determining which files to monitor, since a surprising number of files change in an operational system, having access to a known good copy of each monitored file to establish the baseline value, and protecting the database of file signatures.

- **Signature or Heuristic HIDS**
- The alternative of signature or heuristic based HIDS is widely used, particularly as seen in anti-virus (A/V), more correctly viewed as anti-malware, products. These are very commonly used on Windows systems, and also incorporated into mail and web application proxies on firewalls and in network based IDSs.
- They use either a database of file signatures, which are patterns of data found in known malicious software, or heuristic rules that characterize known malicious behavior. These products are quite efficient at detecting known malware, however they are not capable of detecting zero-day attacsks that do not correspond to the known signatures or heuristic rules.

- **Distributed HIDS**
- Traditionally, work on host-based IDSs focused on single-system stand-alone operation. The typical organization, however, needs to defend a distributed collection of hosts supported by a LAN or internetwork.
- Although it is possible to mount a defense by using stand-alone IDSs on each host, a more effective defense can be achieved by coordination and cooperation among IDSs across the network.
- **Porras points out the following major issues in the design of a distributed IDS :**
- A distributed IDS may need to deal with different sensor data formats. In a heterogeneous environment, different systems may use different sensors and approaches to gathering data for intrusion detection use.

- One or more nodes in the network will serve as collection and analysis points for the data from the systems on the network. Thus, either raw sensor data or summary data must be transmitted across the network. Therefore, there is a requirement to assure the integrity and confidentiality of these data. Integrity is required to prevent an intruder from masking his or her activities by alter ing the transmitted audit information. Confidentiality is required because the transmitted audit information could be valuable.
- Either a centralized or decentralized architecture can be used. With a centralized architecture, there is a single central point of collection and analysis of all sensor data. This eases the task of correlating incoming reports but creates a potential bottleneck and single point of failure. With a decentralized architecture, there is more than one analysis center, but these must coordinate their activities and exchange information.

- A good example of a distributed IDS is one developed at the University of California at Davis
- It consists of three main components:

1. **Host agent module:** An audit collection module operating as a background process on a monitored system. Its purpose is to collect data on security- related events on the host and transmit these to the central manager.
2. **LAN monitor agent module**: Operates in the same fashion as a host agent module except that it analyzes LAN traffic and reports the results to the central manager.
3. **Central manager module:** Receives reports from LAN monitor and host agents and processes and correlates these reports to detect intrusion.

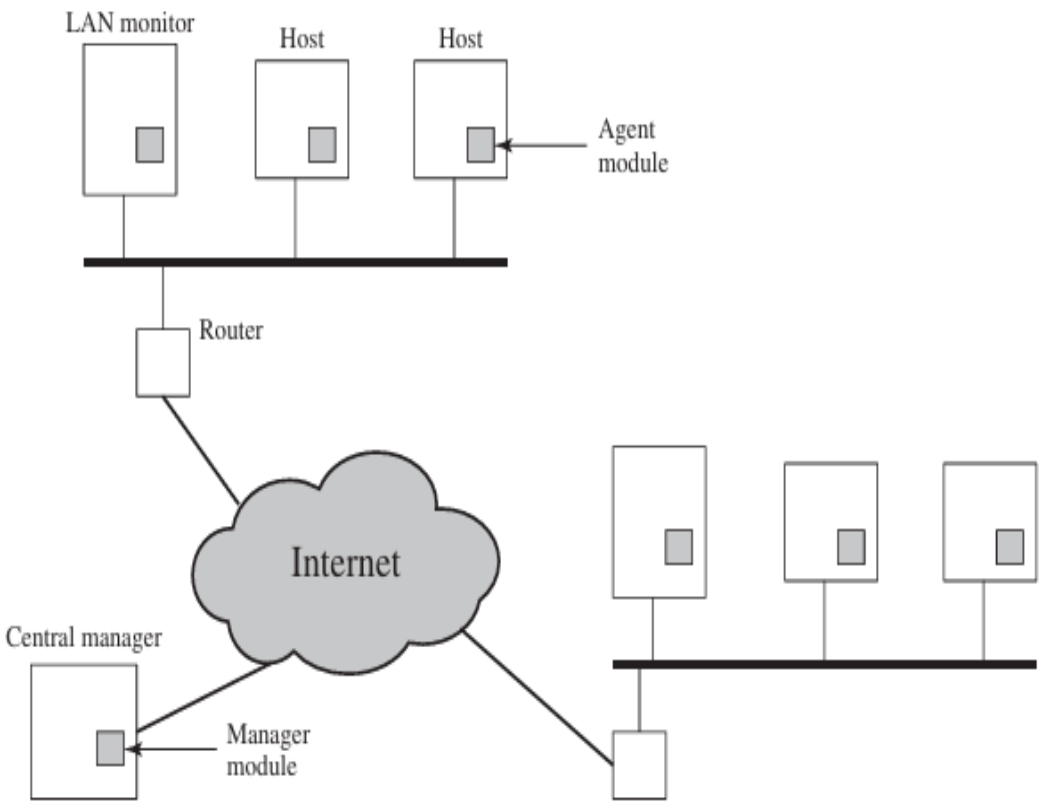


Figure 8.2 **Architecture for Distributed Intrusion Detection**

The scheme is designed to be independent of any operating system or system auditing implementation.

Agent Architecture:

- The agent captures each audit record produced by the native audit collection system.
- A filter is applied that retains only those records that are of security interest.
- These records are then reformatted into a standardized format referred to as the host audit record (HAR).
- Next, a template-driven logic module analyzes the records for suspicious activity.
- At the lowest level, the agent scans for notable events that are of interest independent of any past events. Examples include failed files, accessing system files, and changing a file's access control.

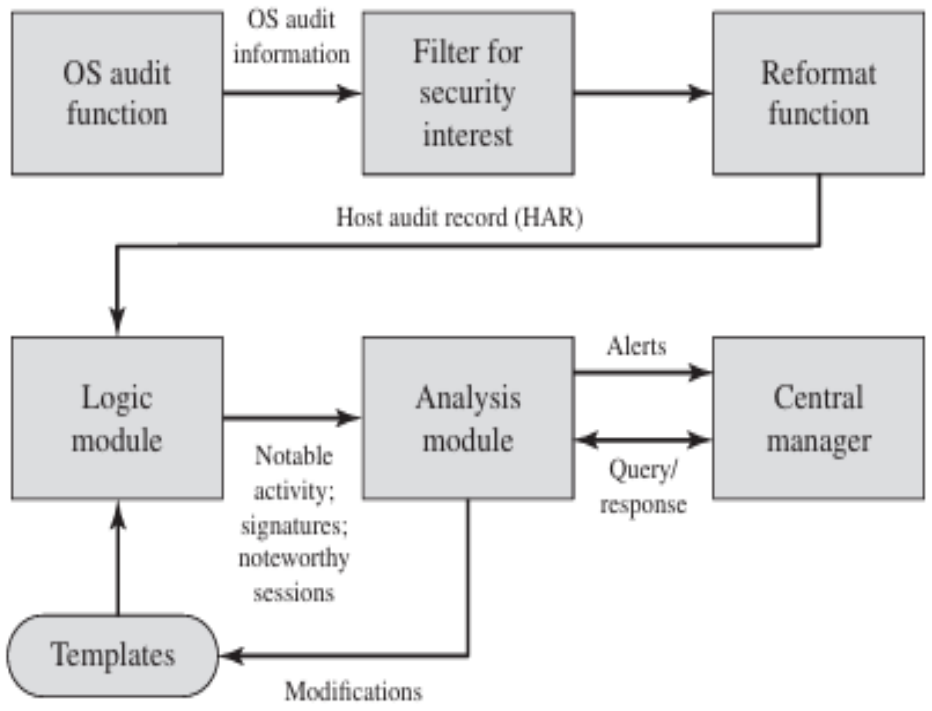


Figure 8.3 **Agent Architecture**

- At the next higher level, the agent looks for sequences of events, such as known attack patterns (signatures). Finally, the agent looks for anomalous behavior of an individual user based on a historical profile of that user, such as number of programs executed, number of files accessed, and the like.
- When suspicious activity is detected, an alert is sent to the central manager. The central manager includes an expert system that can draw inferences from received data. The manager may also query individual systems for copies of HARs to correlate with those from other agents.
- The LAN monitor agent also supplies information to the central manager. The LAN monitor agent audits host-host connections, services used, and volume of traffic. It searches for significant events, such as sudden changes in network load, the use of security-related services, and suspicious network activities.

NETWORK BASED INTRUSION DETECTION SYSTEM

- A network-based IDS (NIDS) monitors traffic at selected points on a network or interconnected set of networks.
- The NIDS examines the traffic packet by packet in real time, or close to real time, to attempt to detect intrusion patterns. The NIDS may examine network-, transport-, and/or application-level protocol activity.
- Note the contrast with a host-based IDS; a NIDS examines packet traffic directed toward potentially vulnerable computer systems on a network. A host-based system examines user and software activity on a host.
- NIDS are typically included in the perimeter security infrastructure of an organization, either incorporated in, or associated with, the firewall. They typically focus on monitoring for external intrusion attempts, by analyzing both traffic patterns and traffic content for malicious activity. With the increasing use of encryption though, NIDS have lost access to significant content, hindering their ability to function well. Thus while they have an important role to play, they can only form part of the solution.

- A typical NIDS facility includes a number of sensors to monitor packet traffic, one or more servers for NIDS management functions, and one or more management consoles for the human interface. The analysis of traffic patterns to detect intrusions may be done at the sensor, at the management server, or some combination of the two.
- **Types of Network Sensors**
- Sensors can be deployed in one of two modes: **inline and passive**.
- An **inline sensor** is inserted into a network segment so that the traffic that it is monitoring must pass through the sensor. One way to achieve an inline sensor is to combine NIDS sensor logic with another network device, such as a firewall or a LAN switch. This approach has the advantage that no additional separate hardware devices are needed; all that is required is NIDS sensor software. An alternative is a stand-alone inline NIDS sensor. The primary motivation for the use of inline sensors is to enable them to block an attack when one is detected. In this case the device is performing both intrusion detection and intrusion prevention functions.

- A **passive sensor** monitors a copy of network traffic; the actual traffic does not pass through the device. From the point of view of traffic flow, the passive sensor is more efficient than the inline sensor, because it does not add an extra handling step that contributes to packet delay.
  - Figure illustrates a typical passive sensor configuration. The sensor connects to the network transmission medium, such as a fiber optic cable, by a direct physical tap.
  - The tap provides the sensor with a copy of all network traffic being carried by the medium. The network interface card (NIC) for this tap usually does not have an IP address configured for it.
  - All traffic into this NIC is simply collected with no protocol interaction with the network. The sensor has a second NIC that connects to the network with an IP address and enables the sensor to communicate with a NIDS management server.

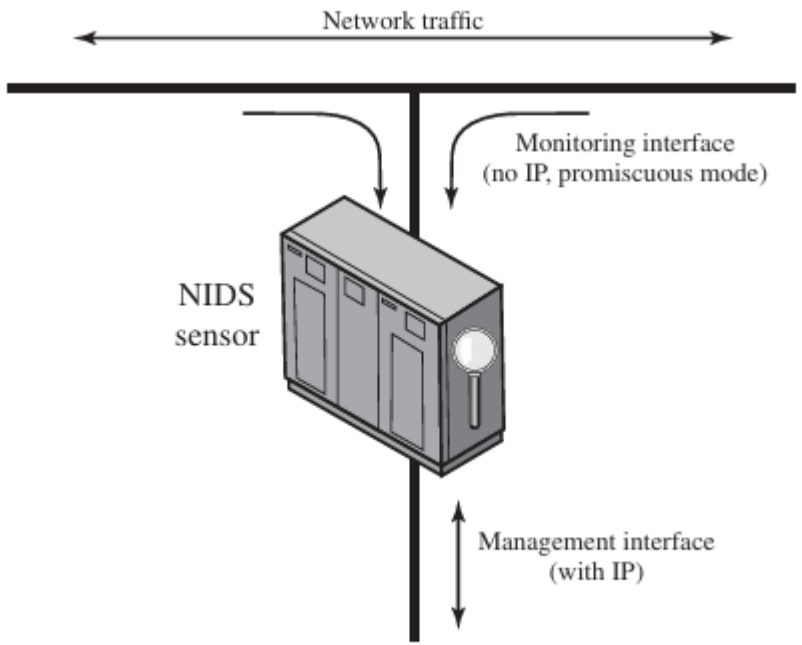


Figure 8.4 **Passive NIDS Sensor**

- Another distinction is whether the sensor is monitoring a wired or wireless network. A wireless network sensor may either be inline, incorporated into a wire less access point (AP), or a passive wireless traffic monitor.
- Only these sensors can gather and analyze wireless protocol traffic, and hence detect attacks against those protocols. Such attacks include wireless denial-of-service, session hijack, or AP impersonation. A NIDS focused exclusively on a wireless network is known as a Wireless IDS (WIDS).
- Alternatively wireless sensors may be a component of a more general NIDS gathering data from both wired and wireless network traffic, or even of a distributed IDS combining host and network sensor data

- **NIDS Sensor Deployment**
- Consider an organization with multiple sites, each of which has one or more LANs, with all of the networks interconnected via the Internet or some other WAN technology.
- For a comprehensive NIDS strategy, one or more sensors are needed at each site. Within a single site, a key decision for the security administrator is the placement of the sensors.

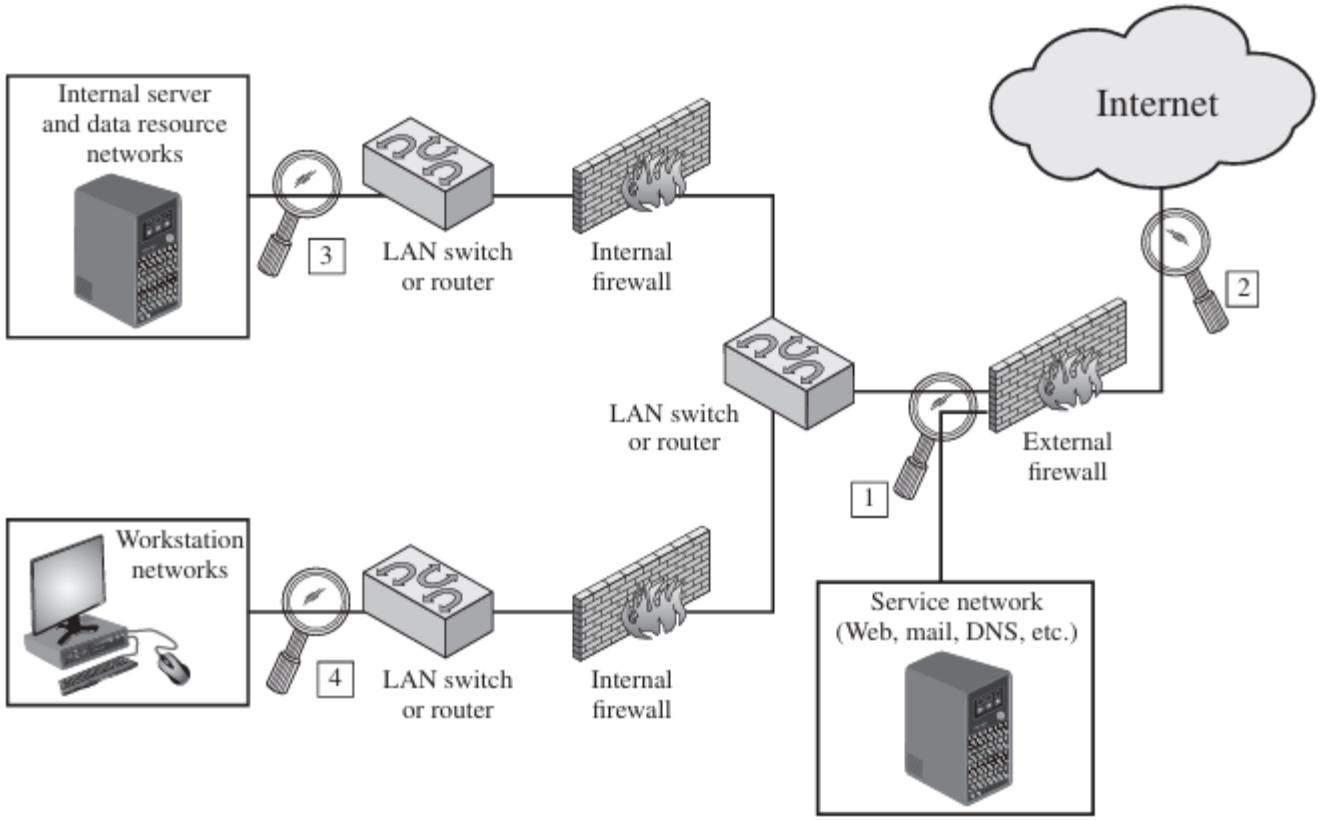


Figure 8.5 **Example of NIDS Sensor Deployment**

- This configuration is typical of larger organizations. All Internet traffic passes through an external firewall that protects the entire facility.
- Traffic from the outside world, such as customers and vendors that need access to public services, such as Web and mail, is monitored. The external firewall also provides a degree of protection for those parts of the network that should only be accessible by users from other corporate sites. Internal firewalls may also be used to provide more specific protection to certain parts of the network.
- **Location 1:**
- A common location for a NIDS sensor is just inside the external firewall (location 1 in the figure). This position has a number of advantages:

• Sees attacks, originating from the outside world, that penetrate the network's perimeter defenses (external firewall).

• Highlights problems with the network firewall policy or performance.

• Sees attacks that might target the Web server or ftp server.

• Even if the incoming attack is not recognized, the IDS can sometimes recognize the outgoing traffic that results from the compromised server.

- **Location 2:**
- Instead of placing a NIDS sensor inside the external firewall, the security administrator may choose to place a NIDS sensor between the external firewall and the Internet or WAN (location 2). In this position, the sensor can monitor all net work traffic, unfiltered. The advantages of this approach are as follows:

• Documents number of attacks originating on the Internet that target the network.

• Documents types of attacks originating on the Internet that target the network.

A sensor at location 2 has a higher processing burden than any sensor located elsewhere on the site network.

- **Location 3:**
- In addition to a sensor at the boundary of the network, on either side of the external firewall, the administrator may configure a firewall and one or more sensors to protect major backbone networks, such as those that support internal servers and database resources (location 3).
- The benefits of this placement include the following:

• Monitors a large amount of a network's traffic, thus increasing the possibility of spotting attacks.

• Detects unauthorized activity by authorized users within the organization's security perimeter. Thus, a sensor at location 3 is able to monitor for both internal and external attacks. Because the sensor monitors traffic to only a subset of devices at the site, it can be tuned to specific protocols and attack types, thus reducing the processing burden.

- **Location 4:**
- Finally, the network facilities at a site may include separate LANs that sup port user workstations and servers specific to a single department. The administrator could configure a firewall and NIDS sensor to provide additional protection for all of these networks or target the protection to critical subsystems, such as personnel and financial networks (location 4). A sensor used in this latter fashion provides the following benefits:

• Detects attacks targeting critical systems and resources.

• Allows focusing of limited resources to the network assets considered of greatest value.

As with a sensor at location 3, a sensor at location 4 can be tuned to specific protocols and attack types, thus reducing the processing burden.

- **Intrusion Detection Techniques in NIDS:**
- As with host-based intrusion detection, network-based intrusion detection makes use of signature detection and anomaly detection. Unlike the case with HIDS, a number of commercial anomaly NIDS products are available. One of the best known is the Statistical Packet Anomaly Detection Engine.
- **Signature Detection:**
- The following are the examples of that types of attacks that are suitable for signature detection:

• **Application layer reconnaissance and attacks:** Most NIDS technologies analyze several dozen application protocols. Commonly analyzed ones include Dynamic Host Configuration Protocol (DHCP), DNS, Finger, FTP, HTTP, Internet Message Access Protocol (IMAP), Internet Relay Chat (IRC), Network File System (NFS), Post Office Protocol (POP), rlogin/rsh, Remote Procedure Call (RPC), Session Initiation Protocol (SIP), Server Message Block (SMB), SMTP, SNMP, Telnet, and Trivial File Transfer Protocol (TFTP), as well as database protocols, instant messaging applications, and peer-to-peer file sharing software. The NIDS is looking for attack patterns that have been identified as targeting these protocols. Examples of attack include buffer overflows, password guessing, and malware transmission.

- **Transport layer reconnaissance and attacks:** NIDSs analyze TCP and UDP traffic and perhaps other transport layer protocols. Examples of attacks are unusual packet fragmentation, scans for vulnerable ports, and TCP-specific attacks such as SYN floods.

- **Network layer reconnaissance and attacks**: NIDSs typically analyze IPv4, IPv6, ICMP, and IGMP at this level. Examples of attacks are spoofed IP addresses and illegal IP header values.

- **Unexpected application services**: The NIDS attempts to determine if the activity on a transport connection is consistent with the expected application protocol. An example is a host running an unauthorized application service.

- **Policy violations:** Examples include use of inappropriate Web sites and use of forbidden application protocols.

- **Anomaly Detection techniques:**
- The following are the examples of the types of attacks that are suitable for anomaly detection:

• **Denial-of-service (DoS) attacks**: Such attacks involve either significantly increased packet traffic or significantly increase connection attempts, in an attempt to overwhelm the target system. Anomaly detection is well suited to such attacks.

• **Scanning:** A scanning attack occurs when an attacker probes a target network or system by sending different kinds of packets. Using the responses received from the target, the attacker can learn many of the system's characteristics and vulnerabilities. Thus, a scanning attack acts as a target identification tool for an attacker. Scanning can be detected by atypical flow patterns at the application layer (e.g., banner grabbing), transport layer (e.g., TCP and UDP port scanning), and network layer (e.g., ICMP scanning).

• **Worms:** Worms spreading among hosts can be detected in more than one way. Some worms propagate quickly and use large amounts of bandwidth. Worms can also be detected because they can cause hosts to communicate with each other that typically do not, and they can also cause hosts to use ports that they normally do not use. Many worms also perform scanning.

- Stateful Protocol analysis (SPA) details this subset of anomaly detection that compares observed network traffic against predetermined universal vendor supplied profiles of benign protocol traffic. This distinguishes it from anomaly techniques trained with organization specific traffic profiles. SPA understands and tracks network, transport, and application protocol states to ensure they progress as expected. A key disadvantage of SPA is the high resource use it requires.
- **Logging of Alerts**
- When a sensor detects a potential violation, it sends an alert and logs information related to the event. The NIDS analysis module can use this information to refine intrusion detection parameters and algorithms. The security administrator can use this information to design prevention techniques. Typical information logged by a NIDS sensor includes the following:

•Timestamp (usually date and time)

• Connection or session ID (typically a consecutive or unique number assigned to each TCP connection or to like groups of packets for connectionless protocols)

• Event or alert type

- Rating (e.g., priority, severity, impact, confidence)
- Network, transport, and application layer protocols
- Source and destination IP addresses
- Source and destination TCP or UDP ports, or ICMP types and codes
- Number of bytes transmitted over the connection
- Decoded payload data, such as application requests and responses
- State-related information (e.g., authenticated username)

DISTRIBUTED OR HYBRID INTRUSION DETECTION SYSTEM

- In recent years, the concept of communicating IDSs has evolved to schemes that involve distributed systems that cooperate to identify intrusions and to adapt to changing attack profiles.
- These combine in a central IDS, the complementary information sources used by HIDS with host-based process and data details, and NIDS with network events and data, to manage and coordinate intrusion detection and response in an organization's IT infrastructure.
- Two key problems have always confronted systems such as IDSs, firewalls, virus and worm detectors. **First**, these tools may not recognize new threats or radical modifications of existing threats. And **second**, it is difficult to update schemes rapidly enough to deal with quickly spreading attacks.
- A separate problem for perimeter defenses, such as firewalls, is that the modern enterprise has loosely defined boundaries, and hosts are generally able to move in and out. Examples are hosts that communicate using wireless technology and employee laptops that can be plugged into network ports. Attackers have exploited these problems in several ways.

- The more traditional attack approach is to develop worms and other malicious software that spreads ever more rapidly and to develop other attacks (such as DoS attacks) that strike with overwhelming force before a defense can be mounted. This style of attack is still prevalent. But more recently, attackers have added a quite different approach: Slow the spread of the attack so that it will be more difficult to detect by conventional algorithms.
- A way to counter such attacks is to develop cooperated systems that can recognize attacks based on more subtle clues and then adapt quickly.
- In this approach, anomaly detectors at local nodes look for evidence of unusual activity. For example, a machine that normally makes just a few network connections might suspect that an attack is under way if it is suddenly instructed to make connections at a higher rate.
- With only this evidence, the local system risks a false positive if it reacts to the suspected attack (say by disconnecting from the network and issuing an alert) but it risks a false negative if it ignores the attack or waits for further evidence. In an adaptive, cooperative system, the local node instead uses a peer-to-peer “gossip” protocol to inform other machines of its suspicion, in the form of a probability that the network is under attack. If a machine receives enough of these messages so that a threshold is exceeded, the machine assumes an attack is under way and responds. The machine may respond locally to defend itself and also send an alert to a central system.

- An example of this approach is a scheme developed by Intel and referred to as autonomic enterprise security.
- This approach does not rely solely on perimeter defense mechanisms, such as firewalls, or on individual host-based defenses.
- Instead, each end host and each network device (e.g., routers) is considered to be a potential sensor and may have the sensor software module installed. The sensors in this distributed configuration can exchange information to corroborate the state of the network (i.e., whether an attack is under way).

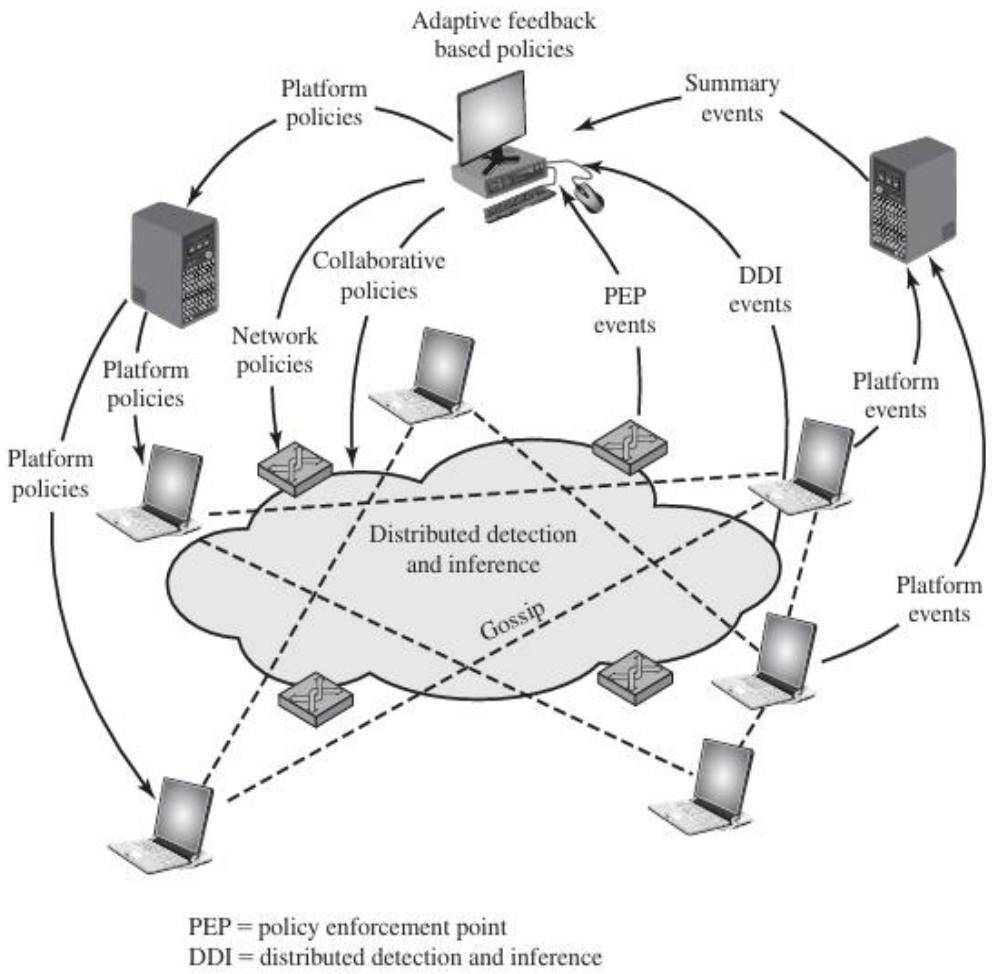


Figure 8.6 **Overall Architecture of an Autonomic Enterprise Security System**

- The Intel designers provide the following motivation for this approach:

1. IDSs deployed selectively may miss a network-based attack or may be slow to recognize that an attack is under way. The use of multiple IDSs that share information has been shown to provide greater coverage and more rapid response to attacks, especially slowly growing attacks.
2. Analysis of network traffic at the host level provides an environment in which there is much less network traffic than found at a network device such as a router. Thus, attack patterns will stand out more, providing in effect a higher signal-to-noise ratio.
3. Host-based detectors can make use of a richer set of data, possibly using application data from the host as input into the local classifier.

- A distributed or hybrid IDS can be constructed using multiple products from a single vendor, designed to share and exchange data. This is clearly an easier, but may not be the most cost-effective or comprehensive solution. Alternatively, specialized security information and event management (SIEM) software exists that can import and analyze data from a variety of sources, sensors, and products. Such software may well rely on standardized protocols, such as Intrusion Detection Exchange Format.
- An analogy may help clarify the advantage of this distributed approach. Suppose that a single host is subject to a prolonged attack and that the host is configured to minimize false positives. Early on in the attack, no alert is sounded because the risk of false positive is high. If the attack persists, the evidence that an attack is under way becomes stronger and the risk of false positive decreases. However, much time has passed.
- Now consider many local sensors, each of which suspect the onset of an attack and all of which collaborate. Because numerous systems see the same evidence, an alert can be issued with a low false positive risk. Thus, instead of a long period of time, we use a large number of sensors to reduce false positives and still detect attacks.

- A central system is configured with a default set of security policies. Based on input from distributed sensors, these policies are adapted and specific actions are communicated to the various platforms in the distributed system.
- The device specific policies may include immediate actions to take or parameter settings to be adjusted. The central system also communicates collaborative policies to all platforms that adjust the timing and content of collaborative gossip messages.
- Three types of input guide the actions of the central system:

• Summary events: Events from various sources are collected by intermediate collection points such as firewalls, IDSs, or servers that serve a specific segment of the enterprise network. These events are summarized for delivery to the central policy system.

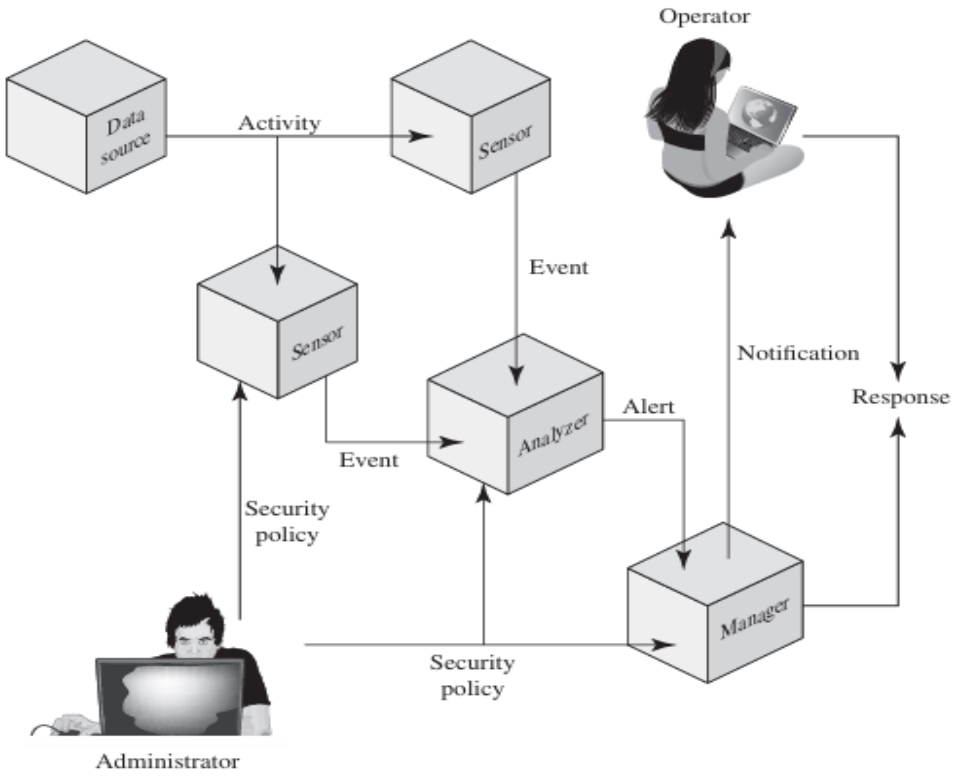
• DDI events: Distributed detection and inference (DDI) events are alerts that are generated when the gossip traffic enables a platform to conclude that an attack is under way.

• PEP events: Policy enforcement points (PEPs) reside on trusted, self- defending platforms and intelligent IDSs. These systems correlate distributed information, local decisions, and individual device actions to detect intrusions that may not be evident at the host level

INTRUSION DETECTION EXCHANGE FORMAT

- To facilitate the development of distributed IDSs that can function across a wide range of platforms and environments, standards are needed to support interoperability.
- Such standards are the focus of the IETF Intrusion Detection Working Group. The purpose of the working group is to define data formats and exchange procedures for sharing information of interest to intrusion detection and response systems and to management systems that may need to interact with them.
- The working group issued the following RFCs in 2007:
- **Intrusion Detection Message Exchange Requirements (RFC 4766):** This document defines requirements for the Intrusion Detection Message Exchange Format (IDMEF). The document also specifies requirements for a communication protocol for communicating IDMEF.
- **The Intrusion Detection Message Exchange Format (RFC 4765):** This document describes a data model to represent information exported by intrusion detection systems and explains the rationale for using this model. An implementation of the data model in the Extensible Markup Language (XML) is presented, an XML Document Type Definition is developed, and examples are provided.

- **The Intrusion Detection Exchange Protocol (RFC 4767):** This document describes the Intrusion Detection Exchange Protocol (IDXP), an application-level protocol for exchanging data between intrusion detection entities. IDXP supports mutual-authentication, integrity, and confidentiality over a connection-oriented protocol.
- Figure illustrates the key elements of the model on which the intrusion detection message exchange approach is based. This model does not correspond to any particular product or implementation, but its functional components are the key elements of any IDS.



Model for Intrusion Detection Message Exchange

- The functional components are as follows:
- **Data source**: The raw data that an IDS uses to detect unauthorized or undesired activity. Common data sources include network packets, operating system audit logs, application audit logs, and system-generated checksum data.
- **Sensor:** Collects data from the data source. The sensor forwards events to the analyzer.
- **Analyzer:** The ID component or process that analyzes the data collected by the sensor for signs of unauthorized or undesired activity or for events that might be of interest to the security administrator. In many existing IDSs, the sensor and the analyzer are part of the same component.
- **Administrator**: The human with overall responsibility for setting the security policy of the organization, and, thus, for decisions about deploying and configuring the IDS. This may or may not be the same person as the operator of the IDS. In some organizations, the administrator is associated with the network or systems administration groups. In other organizations, it is an independent position.

- **Manager:** The ID component or process from which the operator manages the various components of the ID system. Management functions typically include sensor configuration, analyzer configuration, event notification management, data consolidation, and reporting.
- **Operator:** The human that is the primary user of the IDS manager. The operator often monitors the output of the IDS and initiates or recommends further action

- In this model, intrusion detection proceeds in the following manner.
- The sensor monitors data sources looking for suspicious activity, such as network sessions showing unexpected telnet activity, operating system log file entries showing a user attempting to access files to which he or she is not authorized to have access, and application log files showing persistent login failures.
- The sensor communicates suspicious activity to the analyzer as an event, which characterizes an activity within a given period of time.
- If the analyzer determines that the event is of interest, it sends an alert to the manager component that contains information about the unusual activity that was detected, as well as the specifics of the occurrence.
- The manager component issues a notification to the human operator. A response can be initiated automatically by the manager component or by the human operator.
- Examples of responses include logging the activity; recording the raw data (from the data source) that characterized the event; terminating a network, user, or application session; or altering network or system access controls.
- The security policy is the predefined, formally documented statement that defines what activities are allowed to take place on an organization's network or on particular hosts to support the organization's requirements. This includes, but is not limited to, which hosts are to be denied external network access.
- The specification defines formats for event and alert messages, message types, and exchange protocols for communication of intrusion detection information.

HONEYPOTS

▪ Honeypots are decoy (*trick*) systems that are designed to lure (*attract*) a potential attacker away from critical systems. Honeypots are designed to:

- Divert an attacker from accessing critical systems.
- Collect information about the attacker's activity.
- Encourage the attacker to stay on the system long enough for administrators to respond.

▪ These systems are filled with fabricated (*fake*) information designed to appear valuable but that a legitimate user of the system would not access. Thus, any access to the honeypot is suspect. The system is instrumented with sensitive monitors and event loggers that detect these accesses and collect information about the attacker's activities. Because any attack against the honeypot is made to seem successful, administrators have time to mobilize and log and track the attacker without ever exposing productive systems.

- The honeypot is a resource that has no production value. There is no legitimate reason for anyone outside the network to interact with a honeypot. Thus, any attempt to communicate with the system is most likely a probe, scan, or attack. Conversely, if a honeypot initiates outbound communication, the system has probably been compromised.

- Honeypots are typically classified as being either low or high interaction.

- **Low interaction honeypot:** Consists of a software package that emulates particular IT services or systems well enough to provide a realistic initial interaction, but does not execute a full version of those services or systems.

- **High interaction honeypot:** Is a real system, with a full operating system, services and applications, which are instrumented and deployed where they can be accessed by attackers.

- A high interaction honeypot is a more realistic target that may occupy an attacker for an extended period. However, it requires significantly more resources, and if compromised could be used to initiate attacks on other systems. This may result in unwanted legal or reputational issues for the organization running it.

- A low interaction honeypot provides a less realistic target, able to identify intruders using the earlier stages of the attack methodology.

- Honeypots can be deployed in a variety of locations. Figure illustrates some possibilities. The location depends on a number of factors, such as the type information the organization is interested in gathering and the level of risk that organizations can tolerate to obtain the maximum amount of data.

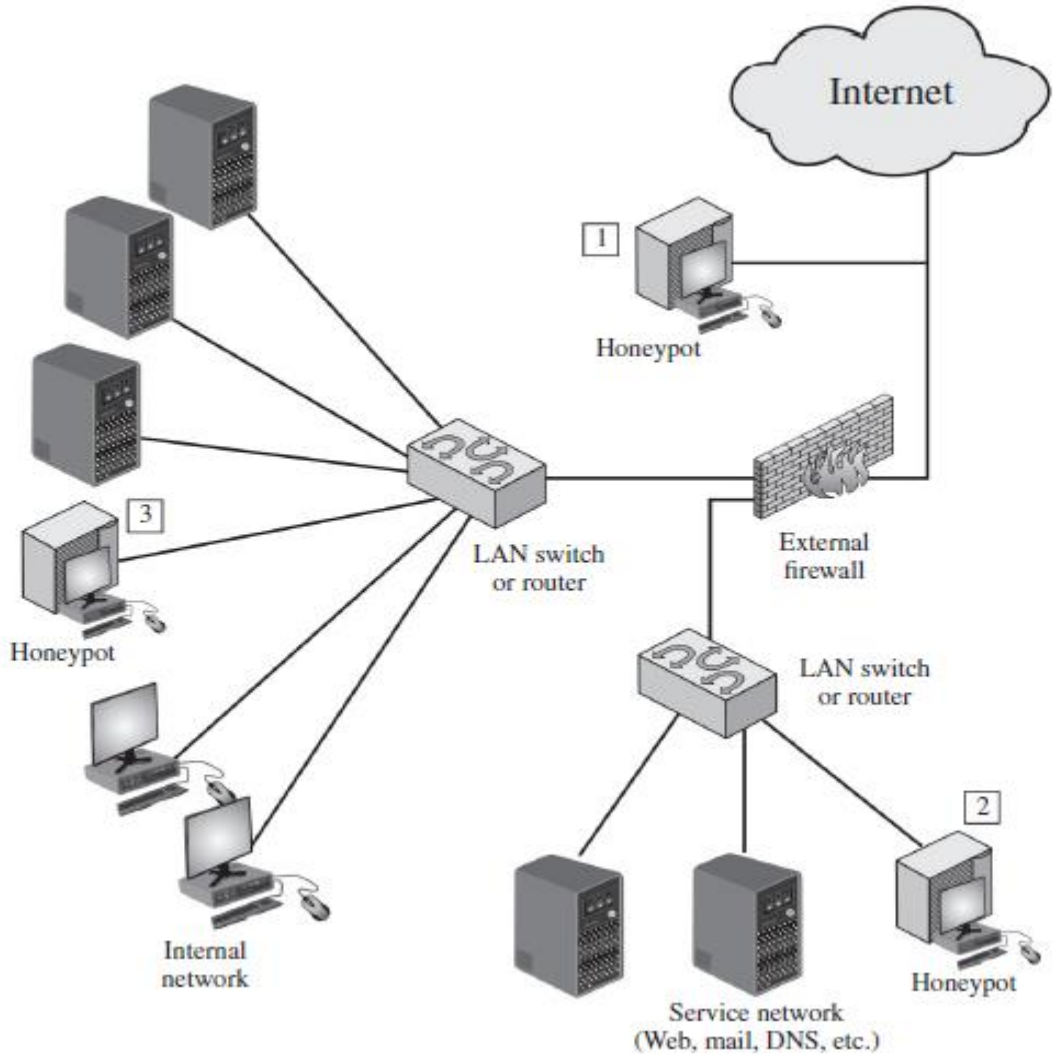


Fig: Example of Honeypot Deployment

- **Location 1:** A honeypot outside the external firewall is useful for tracking attempts to connect to unused IP addresses within the scope of the network. A honeypot at this location does not increase the risk for the internal network. The danger of having a compromised system behind the firewall is avoided. Further, because the honeypot attracts many potential attacks, it reduces the alerts issued by the firewall and by internal IDS sensors, easing the management burden.
- The disadvantage of an external honeypot is that it has little or no ability to trap internal attackers, especially if the external firewall filters traffic in both directions.
- **Location 2:** The network of externally available services, such as Web and mail, often called the DMZ (demilitarized zone), is another candidate for locating a honeypot. The security administrator must assure that the other systems in the DMZ are secure against any activity generated by the honeypot.
- A disadvantage of this location is that a typical DMZ is not fully accessible, and the firewall typically blocks traffic to the DMZ the attempts to access unneeded services. Thus, the firewall either has to open up the traffic beyond what is permissible, which is risky, or limit the effectiveness of the honeypot.
- Note: The DMZ is a portion of a network that separates a purely internal network from an external network.

- **Location 3:** A fully internal honeypot has several advantages. Its most important advantage is that it can catch internal attacks. A honeypot at this location can also detect a misconfigured firewall that forwards impermissible traffic from the Internet to the internal network.

- There are several disadvantages. The most serious of these is if the honeypot is compromised so that it can attack other internal systems. Any further traffic from the Internet to the attacker is not blocked by the firewall because it is regarded as traffic to the honeypot only. Another difficulty for this honeypot location is that, as with location 2, the firewall must adjust its filtering to allow traffic to the honeypot, thus complicating firewall configuration and potentially compromising the internal network.

INTRUSION PREVENTION SYSTEM

- It is an extension of an IDS that includes the capability to attempt to block or prevent detected malicious activity. Like an IDS, an IPS can be host-based, network-based, or distributed/hybrid.
- Similarly, it can use anomaly detection to identify behavior that is not that of legitimate users, or signature/heuristic detection to identify known malicious behavior. Once an IDS has detected malicious activity, it can respond by modifying or blocking network packets across a perimeter or into a host, or by modifying or blocking system calls by programs running on a host.
- Thus, a network IPS can block traffic, as a firewall does, but makes use of the types of algorithms developed for IDSs to determine when to do so. It is a matter of terminology whether a network IPS is considered a separate, new type of product or simply another form of firewall.
- An Intrusion Prevention System (IPS) is a security tool that not only detects potential threats to a computer network but also actively blocks them. It works like a security guard for your network, watching the data traffic that comes in and out. If it spots anything suspicious, such as attempts to exploit vulnerabilities or unauthorized access, it takes immediate action to stop these threats. This could include dropping malicious data packets, blocking suspicious IP addresses, or alerting network administrators. In essence, an IPS helps keep your network safe by identifying and preventing attacks before they can cause harm.

- **Host-Based IPS**
- A host-based IPS (HIPS) can make use of either signature/heuristic or anomaly detection techniques to identify attacks. In the former case, the focus is on the specific content of application network traffic, or of sequences of system calls, looking for patterns that have been identified as malicious.
- In the case of anomaly detection, the IPS is looking for behavior patterns that indicate malware.
- Examples of the types of malicious behavior addressed by a HIPS include the following:

• **Modification of system resources:** Rootkits, Trojan horses, and backdoors operate by changing system resources, such as libraries, directories, registry settings, and user accounts.

• **Privilege-escalation exploits:** These attacks attempt to give ordinary users root access.

• **Access to e-mail contact list:** Many worms spread by mailing a copy of themselves to addresses in the local system's e-mail address book.

• **Directory traversal:** A directory traversal vulnerability in a Web server allows the hacker to access files outside the range of what a server application user would normally need to access.

- Attacks such as these result in behaviors that can be analyzed by a HIPS.
- The HIPS capability can be tailored to the specific platform. A set of general-purpose tools may be used for a desktop or server system.
- Some HIPS packages are designed to protect specific types of servers, such as Web servers and database servers. In this case, the HIPS looks for particular application attacks. In addition to signature and anomaly-detection techniques, a HIPS can use a sandbox approach.
- Sandboxes are especially suited to mobile code, such as Java applets and scripting languages. The HIPS quarantines such code in an isolated system area, then runs the code and monitors its behavior. If the code violates predefined policies or matches predefined behavior signatures, it is halted and prevented from executing in the normal system environment.
- The following are the areas for which a HIPS typically offers desktop protection:

- **System calls:** The kernel controls access to system resources such as memory, I/O devices, and processor. To use these resources, user applications invoke system calls to the kernel. Any exploit code will execute at least one system call. The HIPS can be configured to examine each system call for malicious characteristics.
- **File system access:** The HIPS can ensure that file access system calls are not malicious and meet established policy.
- **System registry settings:** The registry maintains persistent configuration information about programs and is often maliciously modified to extend the life of an exploit. The HIPS can ensure that the system registry maintains its integrity.
- **Host input/output:** I/O communications, whether local or network based, can propagate exploit code and malware. The HIPS can examine and enforce proper client interaction with the network and its interaction with other devices

- **Network-Based IPS**
- A network-based IPS (NIPS) is in essence an inline NIDS with the authority to modify or discard packets and tear down TCP connections. As with a NIDS, a NIPS makes use of techniques such as signature/heuristic detection and anomaly detection.
- Among the techniques used in a NIPS but not commonly found in a firewall is flow data protection. This requires that the application payload in a sequence of packets be reassembled. The IPS device applies filters to the full content of the flow every time a new packet for the flow arrives. When a flow is determined to be malicious, the latest and all subsequent packets belonging to the suspect flow are dropped. In terms of the general methods used by a NIPS device to identify malicious packets, the following are typical:

• Pattern matching: Scans incoming packets for specific byte sequences (the signature) stored in a database of known attacks.

• Stateful matching: Scans for attack signatures in the context of a traffic stream rather than individual packets.

• Protocol anomaly: Looks for deviation from standards set forth in RFCs.

• Traffic anomaly: Watches for unusual traffic activities, such as a flood of UDP packets or a new service appearing on the network.

• Statistical anomaly: Develops baselines of normal traffic activity and through put, and alerts on deviations from those baselines.

- **Distributed or Hybrid IPS**
- The final category of IPS is in a distributed or hybrid approach. This gathers data from a large number of host and network-based sensors, relays this intelligence to a central analysis system able to correlate, and analyze the data, which can then return updated signatures and behavior patterns to enable all of the coordinated systems to respond and defend against malicious behavior.
- A number of such systems have been proposed. One of the best known is the digital immune system.
- The digital immune system is a comprehensive defense against malicious behavior caused by malware. The motivation for this development includes the rising threat of Internet-based malware, the increasing speed of its propagation provided by the Internet, and the need to acquire a global view of the situation.
- The objective of this system is to provide rapid response time so that malware can be stamped out almost as soon as they are introduced. When new malware enters an organization, the immune system automatically captures it, analyzes it, adds detection and shielding for it, removes it, and passes information about it to client systems, so the malware can be detected before it is allowed to run elsewhere.

Figure shows an example of a hybrid architecture designed originally to detect worms. The system works as follows (numbers in figure refer to numbers in the following list):

1. Sensors deployed at various network and host locations detect potential malware scanning, infection or execution. The sensor logic can also be incorporated in IDS sensors.

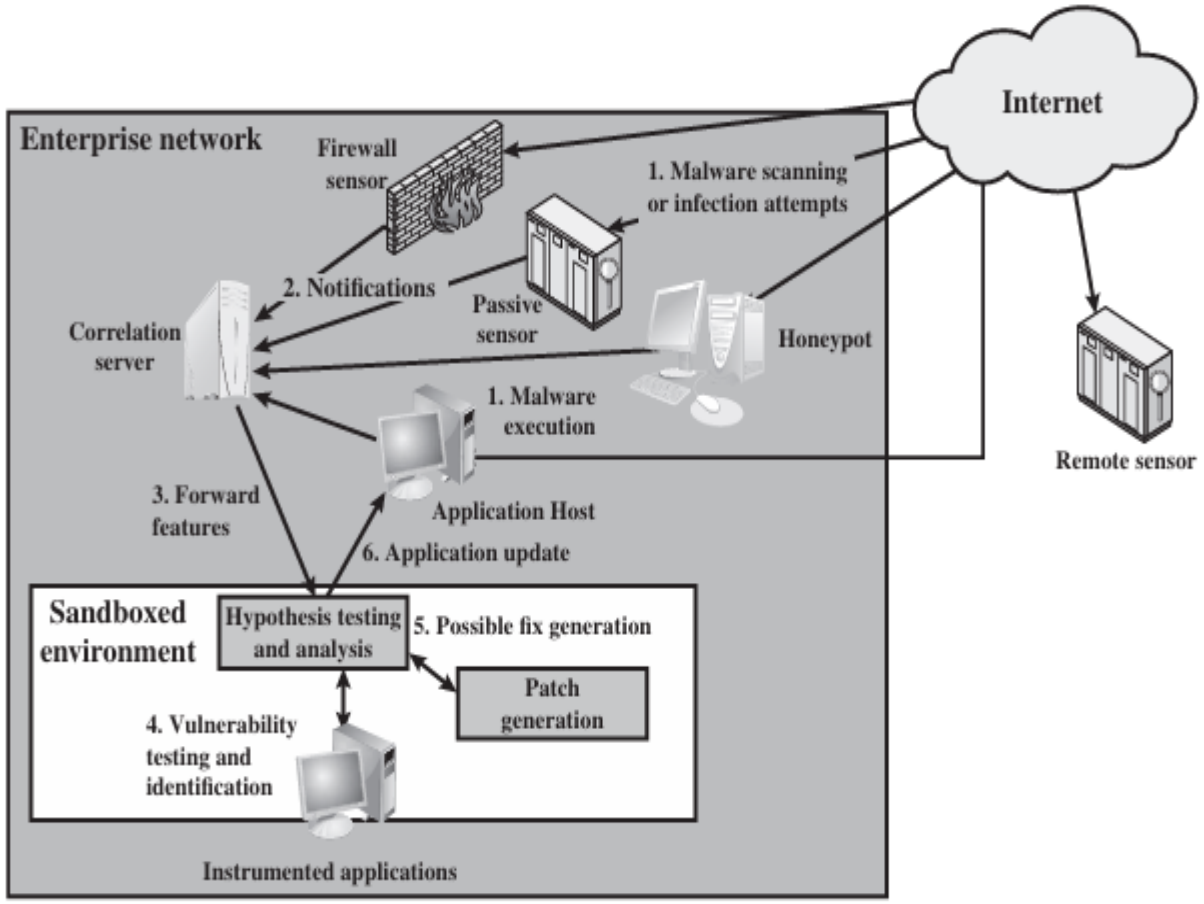


Figure 9.5 **Placement of Malware Monitors (adapted from [SIDI05])**

2. The sensors send alerts and copies of detected malware to a central server, which correlates and analyzes this information. The correlation server deter mines the likelihood that malware is being observed and its key characteristics.

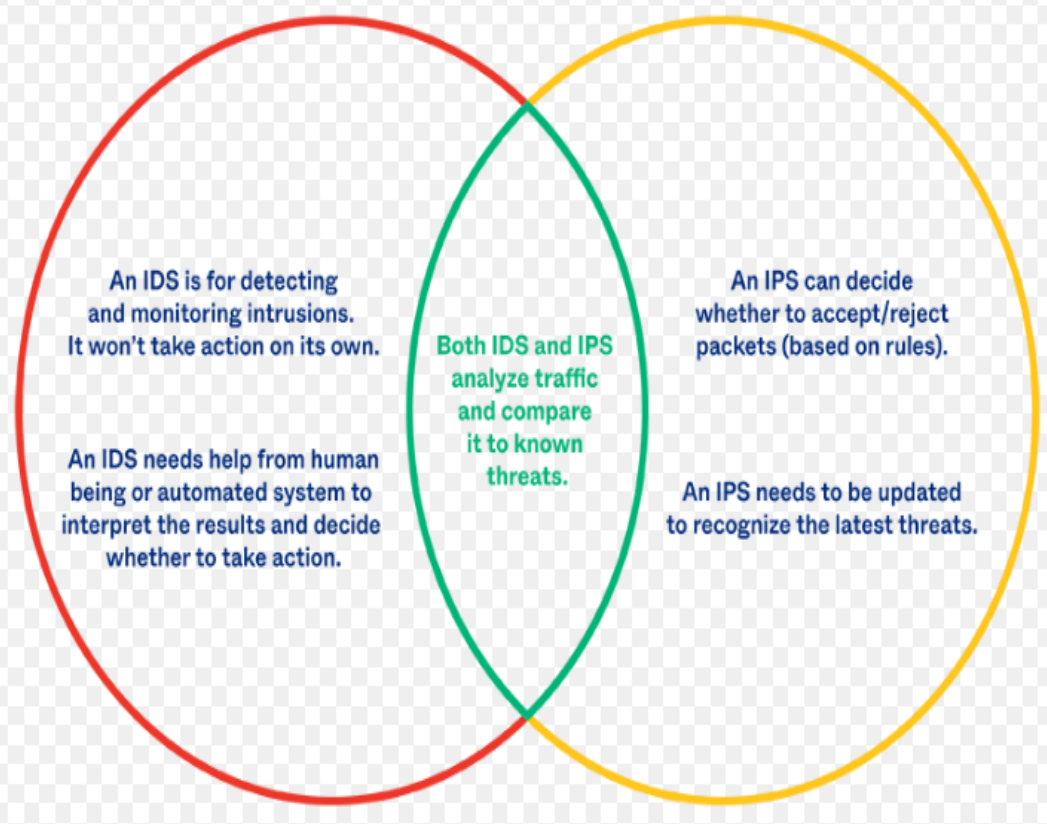
3. The server forwards its information to a protected environment, where the potential malware may be sandboxed for analysis and testing.

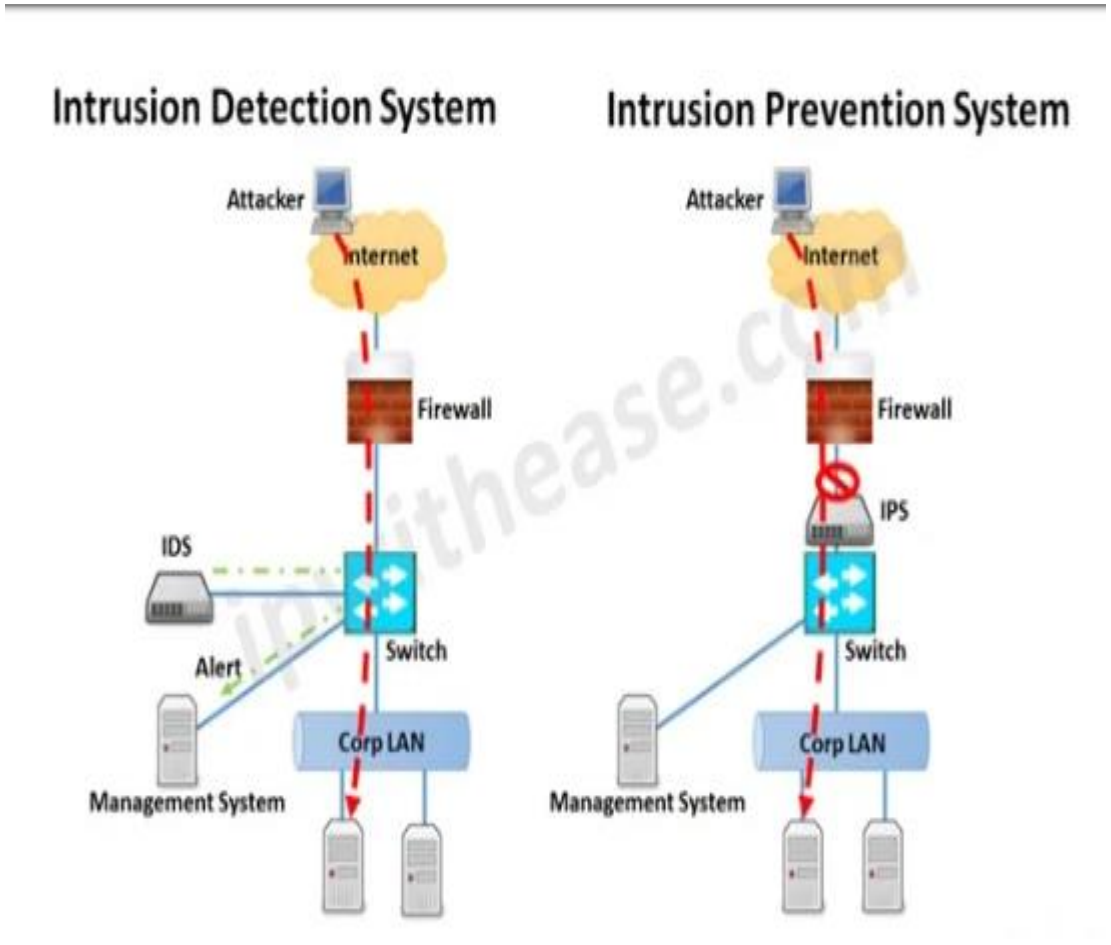
4. The protected system tests the suspicious software against an appropriately instrumented version of the targeted application to identify the vulnerability.

5. The protected system generates one or more software patches and tests these.

6. If the patch is not susceptible to the infection and does not compromise the application’s functionality, the system sends the patch to the application host to update the targeted application.

IDS VS IPS


An IDS is for detecting and monitoring intrusions. It won't take action on its own.
An IDS needs help from human being or automated system to interpret the results and decide whether to take action.
Both IDS and IPS analyze traffic and compare it to known threats.
An IPS can decide whether to accept/reject packets (based on rules).
An IPS needs to be updated to recognize the latest threats.


Intrusion Detection System
Attacker
Internet
Firewall
IDS
Switch
Alert
Corp LAN
Management System
Intrusion Prevention System
Attacker
Internet
Firewall
IPS
Switch
Corp LAN
Management System

- Think of a **honeypot** like a fake house with some attractive items visible through the window to catch a burglar's attention. It's set up on purpose to look easy to break into. However, inside this house, there are hidden cameras and alarms. When a burglar tries to break in, they get caught on camera, and the security team can study what the burglar does. This helps the team learn how burglars operate and improve their real house's security.
- In computer terms, a honeypot is a fake computer system designed to attract hackers. It looks real but is set up to monitor and capture everything a hacker does without risking any real data or systems. This helps cybersecurity experts understand hacker techniques and improve security measures.